8 · Article 14 notifications

These forms prepare the three Art 14 notifications for an actively exploited vulnerability (AEV) or a severe incident (SI), plus the notice to users. Art 14 has applied since 11 Sep 2026 to every in-scope product, including products already on the market (Art 69(3)). Each notification is filed on ENISA's Single Reporting Platform (SRP) to the coordinator CSIRT of the main-establishment Member State, with ENISA given simultaneous access (Art 14(7)); the internal case file stays the authoritative record.

At a glance

Item	Detail
Legal basis	Art 14(1)-(8); Art 3(42); Art 14(5); Art 69(3); Art 64(10)(a); guidance C(2026) 5252 paras 210-221 (approved draft, not formally adopted as at 30 Oct 2026)
Needed for	Every AEV and SI in any product placed on the market, including legacy and out-of-support versions (guidance para 210)
Owner	PSIRT lead; the incident commander declares awareness; a named notification owner per stage
Approver	No approval before the early warning. Legal reviews the 72-hour notification and the final report
When to create	Pre-fill the product data now for each family. File within 24 hours of awareness
When to update	At 72 hours, at the final report, and on CSIRT request (Art 14(6)). Refresh the distribution map whenever sales change
Retention	SRP receipts, notification IDs and user-notice records with the technical documentation for 10 years or the support period (Art 13(13))
Feeds	Template 7 (intake and exploitation determination); Template 6 (user channels); Template 4, Annex VII pt 2(b); Template 2 (risk assessment update after the review)

How to complete

1. Pre-fill the product rows of each form now: name, versions, Member States, support status.
2. On any signal, open a case and assess immediately. Record the UTC awareness time once there is "a reasonable degree of certainty" (guidance para 213).
3. File the early warning within 24 hours of awareness. Do not wait for legal review.
4. Inform impacted users without undue delay (Art 14(8)). The notice is not gated on the filing.
5. File the 72-hour notification. Count 72 hours from awareness, not from the early warning.
6. Track the date the fix became available internally. File the final report on time.
7. Record the SRP notification ID in the case file. Run the post-incident review and update the risk assessment.

Template

Triggers and clocks

Stage	Actively exploited vulnerability	Severe incident	Basis
Trigger	"Reliable evidence that a malicious actor has exploited it" in a system without the owner's permission	Affects, or could affect, the ability to protect "sensitive or important data or functions"; or has led, or could lead, to malicious code in the product or users' systems	Art 3(42); Art 14(5)(a)-(b)
Early warning	24 hours from awareness	24 hours from awareness	Art 14(2)(a); 14(4)(a)
Notification	72 hours from awareness	72 hours from awareness	Art 14(2)(b); 14(4)(b)
Final report	No later than 14 days after a corrective or mitigating measure is available	Within 1 month after the 72-hour notification	Art 14(2)(c); 14(4)(c)
Intermediate update	On CSIRT request	On CSIRT request	Art 14(6)

Suspicion starts triage; reasonable certainty starts the clock. Not reportable: good-faith research or bug-bounty findings without exploitation evidence, and component CVEs not exploitable or not exploited in the product (FAQ 5.2, 5.4; guidance paras 217-218). Exploitation known before 11 Sep 2026 is not reported retroactively. Record "not reportable" decisions with the same rigour.

Routing: the main establishment is where product cybersecurity decisions are predominantly taken. A wrong coordinator CSIRT "may invalidate the notification" (ENISA SRP FAQ 18). The SRP is a web form only, in English, with no API and no sandbox. Use UTC for all times and label estimates.

Illustrative scenario for the example column. AEV: on 14 Nov 2026 the PSIRT confirms from cloud logs and two customer reports that attackers replayed captured Bluetooth unlock commands to open L2 locks on firmware 3.2.0 to 3.2.4. SI: an attacker uses stolen administrator credentials to issue guest keys through the access-management cloud.

Form A: early warning (24 hours), AEV and SI

Field (SRP glossary name)	Applies to	What to enter	Basis	Example: L2 Smart Lock (illustrative)
Type	Both	Actively exploited vulnerability or severe incident	Art 14(2)(a); 14(4)(a)	Actively exploited vulnerability
Title	Both	One line naming product and issue	SRP glossary	L2 Smart Lock: Bluetooth unlock command replay exploited
Summary	Both	What is known, in two or three sentences, with estimates labelled	SRP glossary	Replay of captured unlock commands opens locks on firmware 3.2.0-3.2.4. Two confirmed cases; scale under investigation (estimate)
Product name and version	Both	Commercial name, model, affected firmware and app versions	Art 14(2)(a)	L2 Smart Lock, SKUs L2-STD, L2-KEY, L2-RTF; firmware 3.2.0-3.2.4

Field (SRP glossary name)	Applies to	What to enter	Basis	Example: L2 Smart Lock (illustrative)
Member States where product available	Both	Where available, from the distribution map	Art 14(2)(a); 14(4)(a)	DE, AT, FR, NL, BE [complete from the distribution map]
Date and time became aware	Both	UTC, matching the case file	Guidance para 213	2026-11-14 09:40 UTC
Incident suspected of unlawful or malicious acts	SI only	Yes, no or unknown	Art 14(4)(a)	SI example: Yes, stolen administrator credentials

Form B: notification (72 hours), AEV and SI

Field (SRP glossary name)	Applies to	What to enter	Basis	Example: L2 Smart Lock (illustrative)
General information	AEV: product, exploit and vulnerability. SI: general nature of the incident	Mechanism, affected functionality, attack vector with reachability note, CVE or EUVD ID once assigned	Art 14(2)(b); 14(4)(b)	Unlock tokens lack replay protection over Bluetooth. Attack vector: adjacent. CVE [pending]
Initial assessment	SI	Scope and effect on the product's security so far	Art 14(4)(b)	SI example: [n] guest keys issued to [n] locks; keys revoked
Corrective or mitigating measures taken	Both	What the manufacturer has done	Art 14(2)(b); 14(4)(b)	Cloud now rejects reused tokens; firmware 3.2.5 in test
Measures users can take	Both	Interim steps for users	Art 14(2)(b); 14(4)(b)	Turn off Bluetooth unlock in the app; use keypad unlock until updated

Field (SRP glossary name)	Applies to	What to enter	Basis	Example: L2 Smart Lock (illustrative)
Considered sensitivity	Both	Manufacturer's view of how sensitive the information is	Art 14(2)(b); 14(4)(b)	High until the update is widely installed
PEC indicator	AEV only	"Particularly exceptional circumstances" request; legal decides	SRP AEV 72-hour tab	Not requested

The SRP 72-hour counter currently shows a due time 48 hours after the early warning (ENISA SRP FAQ 26). Counters are visibility aids; the statute's 72 hours from awareness governs.

Form C: final report, actively exploited vulnerability (14 days after the fix)

Field (SRP glossary name)	What to enter	Basis	Example: L2 Smart Lock (illustrative)
Description of severity and impact	Assessed severity rating, classification and rationale; CVSS vector with plain-language reasoning. No scale is prescribed	Art 14(2)(c)	High, CVSS [vector]; physical access to homes possible within Bluetooth range
Malicious actor	Information on the actor if known, else "unknown"	Art 14(2)(c)	Unknown
Details of the security update	Fix version, what it changes, how it is delivered	Art 14(2)(c)	Firmware 3.2.5 adds token nonces; automatic over-the-air update
Date corrective measure became available	Tracked internally; the SRP has no counter for this report	Art 14(2)(c)	2026-11-20; final report due by 2026-12-04

Form D: final report, severe incident (1 month after the 72-hour notification)

Field (SRP glossary name)	What to enter	Basis	Example: L2 Smart Lock (illustrative)
Description of severity and impact	Detailed severity and impact, with rationale	Art 14(4)(c)	[n] locks exposed for [n] hours; no confirmed entry
Type of threat or root cause	Likely threat type or root cause	Art 14(4)(c)	Credential phishing of a cloud administrator; no MFA on one legacy account
Applied and ongoing mitigation	Measures applied and still running	Art 14(4)(c)	MFA enforced for all admin accounts; key-issuance alerting; credential review ongoing

User notice (Art 14(8))

After awareness, inform impacted users and, "where appropriate", all users without undue delay, with the mitigating measures. Use "where appropriate, a structured, machine-readable format". Guidance paras 219-221 allow detail to go first to affected customers and more widely once mitigated. If the manufacturer is not timely, the CSIRTs may inform users. No format is named; CSAF is the obvious candidate but appears in no primary source.

```
Subject: Security notice for [product]: [action required / recommended]

What happened
[Plain description of the vulnerability or incident. No details that help
attackers.]

Who is affected
[Products, models and versions. How to check your version: [steps].]

What we are doing
[Measures taken. Fix version [x.y] expected [date] / available now.]

What you should do now
[Interim steps. Install update [x.y] when offered, or [manual steps].]

More information
Advisory: [URL] (machine-readable version: [CSAF URL])
Questions: [contact], [hours]

[Manufacturer], [date]. Reference: [advisory ID]
```

Example: L2 Smart Lock (illustrative)

```
Subject: Security notice for your L2 Smart Lock: action recommended

What happened
Attackers have opened a small number of L2 locks by replaying Bluetooth
unlock signals recorded nearby.

Who is affected
L2 Smart Locks on firmware 3.2.0 to 3.2.4. Check: app > Settings > About.

What we are doing
We have blocked reused signals in our cloud service. Firmware 3.2.5 fixes
the lock itself and installs automatically.

What you should do now
Until your lock shows 3.2.5, turn off Bluetooth unlock in the app
(Settings > Unlock methods) and unlock with the keypad.

More information
Advisory: https://www.example.com/security/advisories/[ID]
Questions: psirt@example.com, [phone], [hours]

Example Group, [date]. Reference: [advisory ID]
```

Related rules

Rule	Detail	Basis
Products already on the market	Art 14 also applies to products placed before 11 Dec 2027	Art 69(3)
After end of support	Reporting continues	Guidance para 210
Fines	Top tier: up to EUR 15,000,000 or 2.5% of worldwide annual turnover. Enforcement machinery applies from 11 Dec 2027	Art 64(2)
Micro and small enterprises	Exempt from fines for missing the 24-hour early-warning deadlines	Art 64(10)(a)
Format	No Art 14(10) implementing act adopted or drafted; the ENISA SRP glossary is the de facto format	Art 14(10)
SRP outage	Wait and file when it returns (SRP FAQ 25); some national CSIRTs accept email only once an outage is declared	ENISA SRP FAQ
Other regimes	NIS2, GDPR and DORA clocks run separately; no single filing discharges another. The proposed NIS2 Art 23(12) deeming rule is not adopted	KB, Reporting obligations

Common mistakes

- Legal review placed before the 24-hour early warning, delaying the filing.
- A stale distribution map. "Member States where product available" is required at early warning.
- Scanner hits or bug-bounty findings treated as actively exploited, or "not reportable" decisions left undocumented.
- The 72-hour clock read from the SRP counter instead of from awareness; the AEV final report date not tracked internally.
- Synthetic test reports submitted to the live SRP. Rehearse on paper; there is no sandbox.

Template 8 · v1.0 · 31 Oct 2026 · Not legal advice; confirm wording against the Official Journal text before use.